



File No.: RR/00162/2023

RESOLUTION OF RECONSIDERATION APPEAL

Examined the reconsideration appeal filed by ILUNION SEGURIDAD, S.A. (hereinafter, the appellant) against the resolution issued by the Director of the Spanish Agency for Data Protection dated February 14, 2023, and based on the following

FACTS

FIRST: On February 14, 2023, a resolution was issued by the Director of the Spanish Agency for Data Protection in file PS/00452/2022, by virtue of which the following sanctions were imposed on ILUNION SEGURIDAD, S.A.:

- for an infringement of Article 5.1 f) of the GDPR, classified under Article 83.5 of the GDPR, a fine of €10,000 (ten thousand euros).
- for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of €5,000 (five thousand euros).

Said resolution, which was notified to the appellant on February 15, 2023, was issued following the processing of the corresponding sanctioning procedure, in accordance with the provisions of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (LOPDGDD), and subsidiarily under Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), regarding the processing of sanctioning procedures.

SECOND: As proven facts of the aforementioned sanctioning procedure, PS/00452/2022, it was recorded that labor communications were sent by email without using the blind carbon copy option, revealing the personal email addresses of the workers to all recipients of the emails.

THIRD: The appellant submitted on March 15, 2023, to this Spanish Agency for Data Protection, a reconsideration appeal, fundamentally based on the aspects already indicated throughout the sanctioning procedure subject to appeal, arguing that the private security services provided by ILUNION SEGURIDAD, S.A. are generally decentralized and in order to keep workers informed about essential circumstances of their employment relationship, such as their shifts, replacements, vacations, occupational risk prevention, training, etc., it is necessary to maintain agile and effective communication channels based on telephone or email, as communication by postal mail is impossible given the time it requires. On the other hand, it states that sometimes it may be necessary for information to be shared among several workers, so that all of them know that the others...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

They are also informed of the same and resolve general doubts. To this end, on the date of 22/11/2019, the WhatsApp group "REFRESCO" is created, with the phone numbers of a small group of workers, which they had already provided to the company as contact information, as well as their email addresses, within the framework of their employment relationship. This group is only used for matters related to the employment relationship, that is, for the formation of this group of workers. At no time is it used to give daily work instructions, assign tasks, etc. It expresses that the workers are in agreement with the communication channel thus established, participating in it, which is proof of active behavior in accepting that their phone number is used in the WhatsApp group. It adds that except for the creation of this group, the rest of the communications occur via WhatsApp individually. In all the individual WhatsApp communications provided by the complainant, it can be observed that the worker actively participates, thereby accepting the established means of communication, and consequently, the processing of their personal phone data in this manner.

It states that WhatsApp messages became more frequent starting in March 2020, the date when

confinement due to the pandemic was declared, which made sending messages via WhatsApp the most appropriate way to convey last-minute changes in order to maintain a critical service at that time, such as airport surveillance, and due to the existing ERTE situation at that time, which necessitated continuous reassignment of work shifts.

It bases the legitimacy for the use of the mobile phone number on what is established in Article 6.1, paragraphs a), b), and f) of the GDPR due to the existence of a contractual relationship and a legitimate interest.

It argues that the workers consented to the processing of the data, both in the group modality where each accessed the phone data of others, as well as in individual communication; that the processing is also covered under Article 6.1.b) of the GDPR as derived from the resolution of the AEPD R/00026/2021 and SAN 2087/2020, dated July 29; and that there was a legitimate interest, in accordance with what is provided in Article 6.1.f) GDPR, in processing such data in light of the necessity caused by the pandemic.

Finally, it claims the lack of culpability of the entity and explains that in order to prevent similar incidents from occurring, ILUNION SEGURIDAD, S.A., made the decision to adopt the measure of sending a communication to all its middle management to remind them that in ILUNION SEGURIDAD, S.A., both the creation of WhatsApp groups with the personal phone numbers of the workers and the sending of emails without using the blind carbon copy (BCC) option to the personal email addresses of those workers are prohibited. Additionally, guidelines governing the responsible use of instant messaging applications such as WhatsApp have been attached for reminder purposes.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/28

It is also indicated that there is a double sanction for the same act, when there is only one alleged infringing action, which constitutes a clear violation of the principle of non bis in idem; without prejudice to the fact that, if there were two infringements (which is not the case), there would be an ideal concurrence of infringements that requires imposing the corresponding sanction for the most serious infringement (art. 29.5 Law 40/2015).

Finally, it expresses the disproportion of the sanctions imposed for a total of €15,000 in light of the incorrect grading of the sanction, derived from a lack of consideration of the mitigating factors present in the facts and circumstances of the case, and from the untimely and surprising justification for the aggravation of the sanction based on an alleged negligence of my represented party that violates their defense rights; and in light of similar cases where more serious facts have been sanctioned with much more lenient penalties.

LEGAL GROUNDS

I

Competence

The Director of the Spanish Agency for Data Protection is competent to resolve this appeal, in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP) and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD).

II

Response to the allegations presented

In relation to the statements made by the appellant, it should be noted the significant argumentative effort made by the appellant in order to defend the legality of the creation of a WhatsApp group and the use of this channel for corporate communications. In this regard, it is worth remembering that these are not the facts sanctioned by the contested resolution. On the contrary, the verified infringements refer to the fact that an email was sent without using the “blind copy” functionality. As reasoned in the resolution, this has involved both the violation of the confidentiality principle established in Article 5.1.f) of the GDPR and the obligation to establish the necessary security measures provided for in Article 32

of the same legal text.

The responding party basically reiterates the allegations already presented throughout the sanctioning procedure; regarding this particular matter, it should be noted that they were already analyzed and dismissed in Legal Grounds III, IV, V, and VI of the contested Resolution, as transcribed below:

<< III

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/28

Regarding the infringement of Article 5.1 f) of the GDPR

The communication of personal data of a worker to other workers in the company involves the processing of personal data and requires legitimization for such communication to occur lawfully.

Therefore, it will be necessary to analyze on a case-by-case basis whether there is a legal basis for the employer to share personal information of the workers, taking into account the intended purpose and the data processed.

The entity being claimed states that there is consent from the workers for the use of such contact means, considering that there is a clear affirmative action from the workers that would legitimize its use.

On this particular matter, it should be noted in advance that there is no doubt that it is necessary for the execution of the contract that the employer has some means of communication with the workers, which could include the use of instant messaging or email. The employer can use a corporate means provided by him to maintain these communications with the workers of his company, and he could also use the personal means that the worker has voluntarily communicated to the company, given that there is no doubt that workers can voluntarily provide their phone number or email address as a means of communication with the employer regarding work-related matters, as long as it is not an obligation imposed by the employer.

This issue is addressed in the Agency's Guide on "Data protection in labor relations" in the following terms:

"(...) In general, it seems necessary for the execution of the contract that the employer has some means of communication with the workers, and it is essential that the worker provides the company with some form of contact. However, the employment contract does not legitimize the company to request all those data from the worker, as the Supreme Court has pointed out regarding the email address or personal phone number (STS 4086/2015, of September 21, Social Chamber). That is to say, the necessity of the processing must be weighed on a case-by-case basis.

To this end, it will be necessary to analyze in each case the alleged legal basis – which could be the employment contract, consent, or the legitimate interest of the employer – the intended purpose, and the data processed."

Therefore, it will be necessary to take into account the purpose pursued by the employer and the data processed in each case to determine whether in a specific case the processing can be based on any of the bases contained in Article 6 of the GDPR, which in this context could be those contemplated in letters a), b), and f) of Article 6.1 of the GDPR. Regarding the adequacy of these legitimization bases to legitimize the employer's use of instant messaging services or email, the following considerations can be made:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/28

a) Regarding consent, it can be stated that when the worker voluntarily communicates with the employer through their personal mobile phone or personal email address, there exists a "clear affirmative act" of their consent to receive communications regarding labor matters through such means, as declared by the Superior Court of Justice of Asturias, Social Chamber, in its ruling of April

12, 2022, provided that the use of this personal data by the employer is not imposed in the employment contract, as determined by the Supreme Court in the aforementioned Ruling 4086/2015, of September 21, Social Chamber, since in such a case the worker does not provide their “voluntary” consent, as explained in the aforementioned ruling: “(...) given that the worker is the weaker party in the contract, the possibility that this contractual weakness could vitiate their consent to a business provision related to a fundamental right must be excluded, and that given the circumstances - it is a matter of access to a scarce resource such as employment - it can well be understood that consent regarding such an aspect is not entirely free and voluntary (...)”.

In this context, when the employer uses the personal contact data of workers and shares it with other employees, whether by email or through instant messaging, as a “necessary” means for the development of the existing contractual relationship between employees and the company, the processing of this data cannot be based on consent, since consent should not be considered freely given when the interested party does not have true or free choice or cannot deny or withdraw their consent without suffering any detriment (consideration 42). The employee must be able to deny or withdraw consent without suffering any detriment, which prevents this basis of legitimacy from being appropriate to substantiate such processing for this purpose, as the dynamics of the employment relationship would depend on whether the employee freely consents to the processing or not.

b) When sharing information about work matters is “necessary” for the execution of the employment contract signed by the worker and the employer uses corporate means for this, the processing of personal information may be covered by the legitimacy basis provided in Article 6.1.b) of the GDPR. However, in these cases, it will be essential that the information shared is adequate, relevant, and limited to what is necessary in relation to the purposes pursued, as required by the principle of data minimization, as well as the establishment of appropriate technical and organizational measures to prevent unauthorized access to the personal information shared, in order not to violate the principle of integrity and confidentiality set forth in Article 5.1.f) of the GDPR.

In this regard, we stated in the resolution of file EXP202105690, which archived the complaint of a worker regarding the creation of two WhatsApp groups and their inclusion in them by the employer, where personal data related to delivery routes, the individuals performing them, the hours, the location of the vans at the end of the workday, and various information are published, that “the data subject to processing is the minimum necessary for the organization of the particular work carried out by the responding party, which has informed the workers of the purpose of the processing in the WhatsApp groups created with the...

6/28

Purpose of using this communication channel for matters related to the employment contract, working conditions, organization and development of work tasks, and distribution while maintaining confidentiality about them.

Now, the worker has the right to maintain control over the personal data that pertains to them; therefore, when the contact data used by the employer is not corporate but rather for personal use by the workers, the processing of such data, including its disclosure to other colleagues, cannot be justified on the basis of the legal grounds provided for in Article 6.1.b) of the GDPR.

The National Court, Social Chamber, in its ruling of June 27, 2022, summarizes the doctrine established by the chamber itself and by the Supreme Court as follows:

1.- It is doctrine of both this Chamber and Chamber IV of the Supreme Court; the alienation inherent in the employment contract (per Article 1.1 of the Workers' Statute) implies, among other things, the alienation of means, which means that it is the employer who must provide the worker with the necessary means for the development of their employment relationship (Supreme Court ruling of 8-2-2021 - rec 84/2019 - confirming National Court ruling of 6-2-2019 - proc. 318/2018; National Court ruling of 10-5-2021 - case 105/2021).

2.- On the other hand, the Supreme Court ruling of 21-9-2015 - rec 259/2014 - confirming the National Court ruling of 28-1-2014 - case 428/2013 - considered it contrary to the then-current national and European regulations on data protection for the worker to be obliged to provide their personal email and phone number to the company, reasoning that if these were essential for the development of the contract, both should be provided by the company to the worker.

This criterion is also followed in the FAQ of the AEPD: Can the employer request the worker's personal phone number and email address?

"The processing of the worker's personal email and phone number can be disregarded by the employer, given that no regulation requires the worker, for the adequate perfection of their contractual relationship, to provide these data to the employer to whom they provide their services.

That is to say, such processing would exceed what is initially permitted by data protection regulations, and more specifically, the legitimacy of Article 6 of the GDPR based on the execution of a contract.

However, if the circumstances of the provision of services for the company involved personal availability of the worker outside their workplace or working hours, a more moderate and equally effective measure to achieve communication between the company and the worker would be to provide them with a work tool such as a company phone.

In any case, it would be possible for the affected individuals to provide their personal email and phone number, although the collection of this data would have to be voluntary, prior to obtaining the worker's consent, who may subsequently oppose its processing by exercising their rights of opposition or deletion."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/28

In conclusion, the processing of the personal phone number of the employee or their personal email address for the purpose of maintaining the employment relationship cannot be considered "necessary" for the execution of the contract, as required by Article 6.1.b) of the GDPR, in the sense that the main object of the specific contract with the data subject cannot be achieved if the specific processing of the personal data in question is not carried out (Guidelines 2/2019 on the processing of personal data under Article 6, paragraph 1, letter b), of the GDPR in the context of providing online services to data subjects), since the employer can always provide these necessary means to the employees. Consequently, in general terms, this use cannot be justified on the basis of the legal basis contemplated in Article 6.1.b) of the GDPR.

c) Finally, it remains to be analyzed whether the applicable legal basis could be legitimate interest. In relation to this legal basis of legitimate interest, Article 6.1.f) of the GDPR considers the processing to be lawful when "it is necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that such interests do not prevail over the interests or the fundamental rights and freedoms of the data subject which require the protection of personal data (...)". Recital 47 of the GDPR specifies the content and scope of this legitimizing basis for processing: "(47) The legitimate interest of a data controller, including that of a controller to whom personal data may be communicated, or of a third party, may constitute a legal basis for processing, as long as the interests or the rights and freedoms of the data subject do not prevail, taking into account the reasonable expectations of the data subjects based on their relationship with the controller. Such legitimate interest could arise, for example, when there is a relevant and appropriate relationship between the data subject and the controller, such as in situations where the data subject is a customer or is in the service of the controller. In any case, the existence of a legitimate interest would require a meticulous assessment, including whether a data subject can reasonably foresee, at the time and in the context of the collection of personal data, that processing for that purpose may occur. In particular, the interests and fundamental rights of the data subject could prevail over the interests of the data controller when the processing of personal data occurs in circumstances where the data subject does not reasonably expect further processing to take place. Since it is up to the legislator to establish by law the legal basis for the processing of personal data by public authorities, this legal basis should not apply to processing carried out by public authorities in the exercise of their functions. The processing of personal data strictly necessary for the prevention of fraud also constitutes a legitimate interest of the data controller in question. The processing of personal data for direct marketing purposes may be considered to be carried out by legitimate interest."

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/28

It is also important to highlight that public authorities, in the exercise of their functions, cannot base their processing on this legal basis. The legitimate interest of the employer could be an appropriate basis in a labor context, as recognized by the Article 29 Working Party (WP29) in its Opinion 6/2014 on the concept of legitimate interest of the data controller under Article 7 of Directive 95/46/EC, considering that it could be lawful under Article 7, letter (f) of the Directive: “The creation of an internal database of employee contact information containing the name, work address, telephone number, and email address of all employees, to allow employees to contact their coworkers (...) if it is demonstrated that the interest of the data controller prevails and all appropriate measures are taken, including, for example, consultation with employee representatives.”

According to the doctrine of the Court of Justice of the European Union, as established in the Judgment of July 29, 2019 (Case C-40/17, “Fashion ID”), this legal basis requires the concurrence of three cumulative requirements, namely (i) that the data controller or the third party or parties to whom the data is communicated pursue a legitimate interest; (ii) that the processing of personal data is “necessary” for the satisfaction of the legitimate interest pursued; and (iii) that the fundamental rights and freedoms of the data subject do not prevail, for which it will be necessary for the controller to carry out a balancing test between the pursued interest and the interests or rights and freedoms of the data subjects.

Thus, it must be taken into account, in any case, when analyzing whether this legal basis contemplated in Article 6.1(f) of the GDPR can legitimize a specific processing, that there must be a fair balance between the right to the protection of personal data of workers and the interests of the employer, so that the employer's use of personal data exceeds the proportionality test, which must be observed in any restrictive measure of a fundamental right in its triple manifestation of suitability, necessity, and proportionality in the strict sense. In particular, for the processing to pass the necessity test, it will be essential that it was not possible to use a less invasive communication system than the one used.

There is no doubt that there is a conflict between the employer's right and the employees' right to the protection of their personal data, which requires a fair balancing between the need to protect the employee's privacy and the employer's right to ensure the proper functioning of the company.

In this regard, the special circumstances that occurred during the state of alarm declared in our country by Royal Decree 4463/2020 of March 14, 2020, cannot be overlooked.

In our resolution R/00026/2021 of 01/14/2021, taking into account such circumstances, we stated the following:

“(...) it should be noted that communication methods are constantly changing, and companies seek and use organizational tools and

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/28

Simple, fluid, agile, effective, and economical planning, with the advantages it entails for establishing communication with employees, allowing for a correct and efficient functioning of the company.

The use of mobile devices and their tools, email, or other telematic devices or channels, becomes essential for those employees who carry out their functions outside the workplace, as is the case at hand. Therefore, the parties must agree to seek agile communication channels, given that communication by postal means may not be operational in the context of the employment relationship with the claimant (especially considering the health emergency due to Covid-19), except for the sending of payroll or communications that do not require a punctual and immediate action.

In this regard, it is also worth mentioning the ruling 2087/2020, dated July 29, from the National Court, which addresses, in its eighth foundation, the legality of the communication mechanism used by the

company to inform workers, due to the impossibility of delivering the communication in person, as a consequence of the isolations imposed by the health crisis caused by SARS-CoV-2, with the following pronouncement:

"EIGHTH: As a final point of criticism, the acting union questions the communication mechanism used by the company to inform the affected workers of its final decision, as the use of different applications and networks allows for the free circulation of information in a non-verified manner.

The reason cannot be favorably accepted for various reasons. Firstly, because the acting union does not deny that the workers who were ultimately affected by the measure in question had not received the company communication in a verified manner, but rather generically states that 'WhatsApp, email, and other similar applications allow for the circulation of information anonymously.' However, this circumstance has not been verified in the case being judged, where the company has provided different emails sent from an address with the company's domain (the authenticity of which is not in doubt, as the acting party acknowledged all documents submitted otherwise) to workers affected by the ERTE. In fact, it can be verified that in the case of (...) (pages 8 and 9 of descriptor 134), there is even the signature of the worker himself in the corresponding box, which evidences the effective receipt of the document.

On the other hand, we must not forget the particular circumstances surrounding the processing of the ERTE in question, with a state of alarm declared by Royal Decree 4463/2020 of March 14, 2020, whose article 7 limited the freedom of movement of individuals, allowing them to circulate only on public thoroughfares for the following activities: a) Acquisition of food, pharmaceutical products, and essential goods. b) Assistance to health centers, services, and establishments. c) Travel to the workplace to perform their labor, professional, or...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/28

business. d) Return to the place of habitual residence. e) Assistance and care for the elderly, minors, dependents, persons with disabilities, or particularly vulnerable individuals. f) Travel to financial and insurance entities. g) Due to force majeure or a situation of necessity. h) Any other activity of a similar nature that must be carried out individually, unless accompanied by persons with disabilities or for another justified reason.

In short, considering that Article 3.1 of the Civil Code states that we must interpret the rules according to the social reality of the time in which they are to be applied, never have circumstances been so decisive in allowing a departure from what are the ordinary habits and practices in communications between employer and employee, such that we must consider that the means employed by the defendant to inform the workers about their inclusion in the ERTE due to force majeure was an adequate system given the concurrent circumstances at that time, with no further indication that through such a communication channel the fundamental rights of workers' privacy were not safeguarded, nor was the authenticity and veracity of what was communicated guaranteed.

The claim, therefore, must be dismissed."

However, the considerations presented cannot exempt the employer from justifying the "necessity of the measure" and from conducting a fair balancing of the interests involved, guaranteeing the right of opposition of the interested parties, which must be explicitly mentioned to the interested party and presented clearly and separately from any other information, no later than at the time of the first communication with the interested party (art. 21.4 GDPR).

In procedure PS/00078/2021, we stated regarding the absence of the requirement for balancing the following:

Due to the lack of information regarding the proof of balancing, the interested party is deprived of their right to know the legal basis for the processing alleged by the controller, and specifically, when referring to the legitimate interest, they are deprived of their right to know what those legitimate interests alleged by the controller or a third party are that would justify the processing without taking their consent into account.

Likewise, the interested party is deprived of their right to argue why the legitimate interest alleged by the controller could be countered by the rights or interests of the interested party. Since the interested party has not been given the opportunity to argue them against the controller, any balancing carried out by the controller without considering the circumstances that the interested party could allege, who has not been allowed to do so, would be flawed, as it would be an act contrary to a mandatory norm. It is difficult to accept that processing is based on the legitimate interest of the controller when that processing is carried out covertly.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/28

Therefore, it is not appropriate to invoke this legal basis of legitimate interest in the context of an administrative procedure, such as the transfer of the claim or the allegations regarding the opening of the sanctioning procedure. Accepting it would be tantamount to admitting a subsequent or a posteriori legitimate interest, regarding which the requirements established in the personal data protection regulations have not been respected and about which the interested parties have not been informed. Regarding the requirement of "necessity," the resolution refers to it in the following terms: As for the second requirement, however, it is considered that the processing of personal data carried out by MARINS PLAY is not necessary or strictly necessary for the satisfaction of the alleged legitimate interest (the cited ruling of 04/05/2017, C-13/16, Rigas Satskime, in its paragraph 30, states, "As for the requirement that the processing of data be necessary, it should be recalled that exceptions and restrictions to the principle of protection of personal data must be established without exceeding the limits of what is strictly necessary").

This principle, according to which the processing must be strictly necessary for the satisfaction of the legitimate interest, must be interpreted in accordance with what is established in Article 5.1.c) of the GDPR, which refers to the principle of data minimization, stating that personal data shall be "adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed." Thus, less invasive means should always be preferred to serve the same purpose. Necessity here implies that the processing is essential for the satisfaction of the aforementioned interest, so that if this objective can be reasonably achieved in another way that produces less impact or is less intrusive, the legitimate interest cannot be invoked.

In this regard, according to these criteria, this basis for legitimization cannot be appreciated when the circumstances outlined do not occur, to which should be added the criterion of our jurisprudence, previously mentioned regarding the processing of the personal phone number of the worker or their personal email address for the purpose of maintaining the employment relationship, consisting of the fact that when they are essential for the performance of the contract, both must be provided by the company to the worker in order not to break the necessary detachment of the means that characterizes the employment contract. The requirement for the worker to provide these means could imply a manifest abuse of business rights, as inferred from the SAN of February 6, 2019.

Having established the above and focusing on the infringement being examined – breach of the duty of confidentiality – it is necessary first to analyze whether the creation of the WhatsApp group "REFRESCO" in 2019 with the personal phone numbers of 5 workers for matters related to the training of these workers can be justified under any of the examined bases of legitimization. In this regard, the responding party states that the workers agree with the established communication channels, participating in them, and that the names of the individuals who sign the claim do not match the names.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/28

of the members of the chat, which is why it is appropriate to bring up the doctrine of the National Court

established, among others, in the SAN of June 13, 2017, and SAN of June 26, 2020, which considers it necessary to appreciate the existence of an infringement due to lack of consent that the affected party themselves must deny its existence, as consent is personal and individual. Therefore, the imposition of a sanction for the narrated facts is not warranted since none of the members of the chat have manifested the absence of consent.

On the contrary, it must be declared that the principle enshrined in Article 5.1.f) of the GDPR has been violated due to the sending by the respondent of two emails without using the blind carbon copy option, revealing the complainant's email address to the other recipients without their consent and without any other applicable legal basis under Article 6 of the GDPR.

Consequently, taking into account the considerations presented, it cannot be concluded that the respondent entity had a legal basis that justified the disclosure of the complainant's personal email address. Therefore, this Agency considers that providing personal data to third parties, specifically an email address, without a legal basis constitutes a breach of confidentiality that contravenes the principle of integrity and confidentiality set forth in Article 5.1.f) of the GDPR.

In this regard, the respondent entity, by sending the email without using the BCC option, has infringed Article 5.1.f) of the GDPR.

IV

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

The principles relating to the processing of personal data are regulated in Article 5 of the GDPR, which establishes that "personal data shall be:

- a) processed lawfully, fairly, and transparently in relation to the data subject ('lawfulness, fairness, and transparency');
- b) collected for specified, legitimate purposes and not further processed in a manner that is incompatible with those purposes; in accordance with Article 89, paragraph 1, further processing of personal data for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes shall not be considered incompatible with the initial purposes ('purpose limitation');
- c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ('data minimization');
- d) accurate and, where necessary, kept up to date; all reasonable steps must be taken to ensure that personal data that are inaccurate with respect to the purposes for which they are processed are erased or rectified without delay ('accuracy');
- e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes of the processing of personal data; personal data may be stored for longer periods insofar as they are processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, without prejudice to the application of appropriate technical and organizational measures required by this Regulation to protect the rights and freedoms of the data subject ('storage limitation');
- f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality').

The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it ('accountability')."

The infringement of Article 5.1.f) of the GDPR may be sanctioned with a fine of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5.a) of the GDPR, which states as an infringement "the breach of the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

Article 72.1.a) of the LOPDGDD states that "based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years, which constitute a substantial breach of the articles mentioned therein, and in particular, the following:

- a) The processing of personal data in violation of the principles and guarantees established in Article 5

of Regulation (EU) 2016/679.”

V

On the infringement of Article 32 of the GDPR

As highlighted in legal basis II, the identification of a security breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

The examination of the documentation in the file does not allow for the appreciation of diligent behavior on the part of the respondent, who sent two communications to a plurality of recipients without concealing the addresses.

The respondent has not been able to justify that there were adequate security measures in place to ensure the confidentiality of the data in the email transmissions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/28

Furthermore, by sending communications to the personal email addresses of the workers without using the blind carbon copy (BCC), it implies that the security measures of the entity being claimed are not adequate according to data protection regulations.

In accordance with the available evidence, it is considered that the known facts constitute an infringement, attributable to the respondent, for violation of Article 32 of the GDPR.

VI

Classification and qualification of the infringement of Article 32 of the GDPR

The security in the processing of personal data is regulated in Article 32 of the GDPR, which establishes the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of the processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather establishes that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the probability and severity risks to the

rights and freedoms of the data subjects.

In this regard, it should be noted that there are tools available in the market that reduce the risk of mistakenly sending emails to multiple recipients without using the blind carbon copy option, by keeping recipients hidden by default.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must take into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a verification process (which is not an audit), assessment, and evaluation of the effectiveness of the measures. In any case, when assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In the case at hand, the respondent, by sending an email without using the blind carbon copy option, is failing to comply with their obligation to apply appropriate technical and organizational measures to ensure an adequate level of security in the processing of personal data as set out in Article 32 of the GDPR, especially considering that there are tools available in the market that reduce the risk of mistakenly sending emails to multiple recipients without using the blind carbon copy option.

Article 83.4 of the GDPR establishes that administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total global annual turnover of the previous financial year, whichever is higher, shall be imposed when the following obligations are violated:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

Article 73 of the LOPDGGD, under the heading “Infringements considered serious for the purposes of prescription,” provides:

“According to Article 83.4 of Regulation (EU) 2016/679, the following infringements shall be considered serious and shall be subject to a two-year statute of limitations, which involve a substantial violation of the articles mentioned therein, and in particular the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/28

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

g) The breach, as a consequence of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

III

Principle of culpability

The appellant claims that the sanctioning resolution would have violated the principle of culpability. According to this principle (Article 28 of Law 40/2015), the administrative sanctioning law indeed imposes the obligation that the behaviors that are sanctioned correspond to one of the two criteria of attribution, either by intent or by negligence.

The factors that the appellant provides in support of denying the concurrence of this principle would be the following:

- Only two emails are provided, implicating only a small group of workers, apparently 40.
- At no time was the sending of those two emails done consciously with the intent to violate rights, nor was it done negligently, clearly culpably, but with the objective of informing all workers at once and ensuring that everyone knew that others were aware of the same, in the manner of a bulletin board.
- The respondent, as soon as it became aware of the allegations through the request (E/00631/2021)

of 02/02/2021, in order to prevent similar incidents from occurring, ILUNION SEGURIDAD, S.A. decided to adopt the measure of sending a communication to all its middle managers to remind them that in ILUNION SEGURIDAD, S.A., both the creation of WhatsApp groups with the personal phone numbers of workers and the sending of emails without using the blind carbon copy (BCC) option to the personal email addresses of those workers are prohibited.

Well, none of these would prove the alleged lack of culpability. The first refers only to the small number of emails sent, which at most could be taken into account for determining the amount of the sanction, but never to rule out the existence of culpability.

The second refers to the alleged non-existence of an "intent to violate rights." This last point would rule out, if confirmed, the concurrence of intent in the action, but never negligence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/28

Finally, the measures adopted after the opening of the file (the third factor alleged) obviously cannot exempt from culpability in facts that occurred prior.

As the appellant itself indicates, to appreciate the concurrence of the principle of culpability, it must be established that intent or negligence has occurred in the commission of the infringement. In this case, the sanctioning resolution sufficiently motivates the non-existence of security measures that would have prevented the loss of confidentiality of personal data from occurring. In this regard, the only measure invoked in this appeal refers to a moment after the events. Indeed, the appellant states that "as soon as it became aware of the allegations," the instruction was transmitted not to create WhatsApp groups with personal phone numbers, nor to send emails without using the "BCC" functionality.

For all these reasons, the concurrence of the principle of culpability cannot be ruled out; rather, the opposite is true, that is, the lack of sufficient measures allowed the loss of confidentiality to occur.

IV

Possible concurrence of infringements

In this regard, the appellant invokes the possibility of a proscribed "non bis in idem," or subsidiarily, the existence of a medial concurrence of infringements among those attributed in the file, that is, the violations of Articles 5.1.f) and 32 of the GDPR.

In this regard, the following should be indicated:

Non bis in idem.

The infringements in the field of data protection are classified in paragraphs 4, 5, and 6 of Article 83 of the GDPR. It is a classification by reference, fully accepted by our Constitutional Court. In this sense, Article 71 of the LOPDGDD also refers to them by stating that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

In this sense, the Opinion of the Council of State of October 26, 2017, regarding the Draft Organic Law on the Protection of Personal Data states that "The European Regulation does classify, even if it does so in a generic sense, the behaviors constitutive of infringement: indeed, paragraphs 4, 5, and 6 of its Article 83 contain a catalog of infringements for violation of the provisions of the European norm indicated in those paragraphs. Article 72 of the Draft Law assumes, not in vain, the existence of said catalog, when it states that 'acts and behaviors that constitute a violation of the content of paragraphs 4, 5, and 6 of the European Regulation and of this organic law constitute infringements.'"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/28

The infringements established in Articles 72, 73, and 74 of the LOPDGDD are only for the purposes of

prescription, as stated at the beginning of each of these provisions. This necessity arose in our State since there is no reference in the GDPR regarding the prescription of infringements, as this legal institute is not common to all EU Member States.

We must start from the premise that the GDPR is a directly applicable legal norm, which has been developed by the LOPDGDD only in what the former allows. This is evident, particularly regarding prescription, in the preamble of the LOPDGDD when it states that "The categorization of infringements is introduced solely for the purpose of determining the prescription periods, with the description of typical behaviors having as its only object the exemplary enumeration of some of the sanctionable acts that must be understood as included within the general types established in the European regulation. The organic law regulates the cases of interruption of prescription based on the constitutional requirement of knowledge of the facts attributed to the person."

It is the application and interpretation of the GDPR, and not the LOPDGDD, that determines the severity of an infringement based on a series of conditions provided for therein.

As we can see, there is no classification in the GDPR of very serious, serious, or minor infringements typical of the Spanish legal system, nor can it be deduced from its wording that the violation of the provisions of Article 83.4 of the GDPR corresponds to minor infringements and the provisions of Article 83.5 or Article 83.6 of the GDPR correspond to serious infringements.

Thus, Recital 148 speaks of serious infringements in contrast to minor ones when it states that "In the case of a minor infringement, or if the fine that would likely be imposed would constitute a disproportionate burden for a natural person, instead of a sanction by fine, a warning may be imposed. However, special attention must be paid to the nature, gravity, and duration of the infringement, its intentional character, the measures taken to mitigate the damages suffered, the degree of responsibility or any relevant prior infringement, the manner in which the supervisory authority became aware of the infringement, compliance with measures ordered against the responsible party or processor, adherence to codes of conduct, and any other aggravating or mitigating circumstances."

For all these reasons, the severity of an infringement is determined for the purposes of the GDPR and with the elements provided by it.

Thus, the classification of infringements for the purposes of prescription under the LOPDGDD has no bearing on the determination of the severity of the infringement for the purposes of the GDPR nor regarding the imposition of the corresponding fines, if applicable.

By way of mere illustration, we indicate that the same conduct, such as the lack of information in a company's privacy policy, may be considered serious or minor for the purposes of the Regulation (taking into account the circumstances mentioned in Recital 148 in relation to the provisions of Article 83 of the GDPR, as the non-compliance by a multinational company is not the same as that by a self-employed individual) and in both cases with minor prescription. The severity of an infringement will determine its sanction.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/28

As concluded by the Council of State, the European model of sanctions in the GDPR entails a wide range in the amount of the sanction, depending on the concurrence of the circumstances of Article 83.2, which are objective and verifiable by the courts. In fact, as is evident from the STC 150/2020 ruling itself, what is considered contrary to the principle of definiteness and *lex certa*, the material aspect of Article 25 CE, is:

entrusting such correspondence entirely to judicial or administrative discretion, "since this would amount to a mere blank authorization to the administration by a legally empty norm."

In the GDPR, a norm that establishes infringements and sanctions, such an unwanted circumstance by the Constitutional Court does not occur, such as entrusting "entirely" (sic) to administrative discretion the correspondence between infringement and sanction. Quite the contrary. Article 83.4 GDPR and Article 83.5 GDPR already establish a first distinction regarding the amount of the sanctions to be imposed according to the infringed provisions. Article 83.6 GDPR, on the other hand, also properly

delineates the infringement. Article 83.2 GDPR, on the other hand, contains the circumstances that the European legislator considers that the supervisory authorities must take into account to determine the amount of the sanction, which are circumstances that do not depend on "administrative discretion," but rather on an objective assessment, and reviewable by the courts.

Finally, it should be mentioned that constitutional doctrine (see STC 150/2020) only addresses those norms in which the legislator has established the categorization of infringements into three categories (minor, serious, or very serious). This is not the case here. And it does not seem that the Constitution inexorably requires the legislator to always divide infringements into minor/serious/very serious. What the Constitutional Court proclaims is that the regulated party can foresee the correspondence between the infringing conduct and the possible sanction, which undoubtedly occurs here, as the GDPR determines the infringing conducts and the possible sanctions, without there being, on the other hand, any taint of "unconstitutionality" in a European "Regulation," which by virtue of the principle of direct effect (Van Gend en Loos ruling) and primacy (Costa v ENEL ruling) displaces all state regulations, even those of constitutional rank, as is well known (Costa v ENEL ruling: the objectives of the Treaties would be undermined if Union Law could be subordinated to domestic law).

Well then, as can be inferred from the previous foundation, there is a difference between the violation of Article 5.1.f and Article 32 of the GDPR. The different typification in even distinct sections of Article 83 of the GDPR and the different qualification of both for the purposes of prescription in the LOPDGDD corroborate this.

Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of personal data, which may or may not occur due to the absence or deficiency of security measures. This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it specifies "through the application of appropriate technical and organizational measures," which are not strictly security measures.

As we have pointed out earlier, when Article 5.1.f) of the GDPR refers to appropriate technical or organizational measures to guarantee the rights and freedoms of the data subjects within the framework of compliance management of the GDPR...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/28

is made in the sense provided in Article 25 of the GDPR regarding privacy by design.

This provision states that,

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects" (the underlining is ours).

We reiterate that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle.

However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Security measures. Only security measures.

Moreover, its objective is to ensure a level of security appropriate to the risk, while in the case of Article 5.1(f) of the GDPR, confidentiality and integrity must be guaranteed. As can be seen, the two articles pursue different purposes, although they may be related.

Well, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a security breach, the infringement of Article 5.1(f) of the GDPR is specified in a clear loss of confidentiality and availability, while the infringement of Article 32

of the GDPR is reduced to the absence and deficiency of security measures (only security measures). In fact, if the security measures had been detected in this procedure by the AEPD without the loss of confidentiality and availability occurring, it would have only been sanctioned under Article 32 of the GDPR.

And all this against the allegations made to the contrary, which consider that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 5.1(f) of the GDPR is not limited to ensuring security appropriate to the risk, but to ensuring integrity and availability. And not only through security measures but through all kinds of appropriate technical or organizational measures.

As we have indicated, Article 5.1(f) of the GDPR sanctions a loss of availability and confidentiality only, while Article 32 of the GDPR addresses the absence and deficiency of the security measures implemented by the data controller. We add that absent or deficient security measures infringe the GDPR regardless of whether there has been a loss of confidentiality and availability.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/28

Medical Competition

First of all, it should be noted that although both infringements are classified under Article 83.5 of the GDPR, there is not one that is supposedly more serious and another that is supposedly less serious. Second, Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR.

1.

The GDPR is a closed and complete system.

The GDPR is a community regulation directly applicable in the Member States, which contains a new, closed, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

In relation specifically, and also, to the sanctioning regime provided therein, its provisions apply immediately, directly, and integrally, providing a complete and gapless system that must be understood, interpreted, and integrated absolutely, completely, and integrally, thus preserving its ultimate purpose, which is the effective and real guarantee of the fundamental right to the Protection of Personal Data. The contrary results in a reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (Article 83.2 of the GDPR) or specifies the existing rule regarding a possible medical competition (Article 83.3 of the GDPR).

In addition to the above, we must add that the GDPR does not allow for the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of Article 83.7 of the GDPR). The LOPDGDD only develops or specifies some aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the purpose intended by the European legislator is to implement a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that,

“(2) The principles and rules regarding the protection of individuals with regard to the processing of their personal data must, regardless of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of individuals.” (the underlining is ours)

It further indicates in Recital 13 of the GDPR that,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/28

“(13) To ensure a consistent level of protection for individuals throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including microenterprises and small and medium-sized enterprises, and offers individuals in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to guarantee coherent supervision of the processing of personal data and equivalent sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of personal data in the Union is not restricted or prohibited for reasons related to the protection of individuals with regard to the processing of personal data.” (the underlining is ours)

In this system, the determining factor of the GDPR is not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR combined with the provisions of Article 83 of the GDPR show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed alongside the corrective measures or in substitution for them.

All of this aims to enforce compliance with the GDPR, prevent non-compliance, promote compliance, and ensure that the infringement is not more profitable than compliance.

Therefore, Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

Fines must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR. For this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a different legal framework than that provided in the GDPR, would undermine the effectiveness of the system, losing its meaning and teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/28

would diminish the mechanisms for the protection of the rights and freedoms of citizens and would be contrary to the spirit of the GDPR.

The GDPR has its own principle of proportionality that must be applied in its strict terms.

2.

There is no legal gap, there is no supplementary application of Article 29 of the LRJSP

In addition to what has been stated, it should be noted that there is no legal gap regarding the application of medial concurrence. Neither the GDPR allows nor does the LOPDGDD provide for the

supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no provision for supplementary application regarding the LRJSP, which does not contain any provision related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or supplementary application of the same, nor can the section relating to medial concurrence be applied for identical reasons.

Thirdly, and focusing on the specific case examined, it should be emphasized that there is no medial concurrence.

Article 29.5 of the LRJSP establishes that "When the commission of an infringement necessarily derives from the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, medial concurrence occurs when in a specific case the commission of one infringement is a necessary means to commit another different one.

The established facts determine the commission of two distinct infringements, without the violation of Article 32 of the GDPR, as asserted by the appellant, being the necessary means by which the infringement of Article 5.1.f) of the GDPR occurs (violation of the principle of confidentiality).

V

Proportionality of the sanction

The appellant claims that the amount of the imposed sanctions would be disproportionate. In this regard, he bases his argument solely on the significant reduction of the amount made by this Agency between the proposed resolution and the resolution.

Indeed, while in the former it was proposed to impose sanctions of €100,000 (Article 5.1.f) and €50,000 (Article 32), the amounts finally imposed were €10,000 and €5,000 respectively.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/28

This is due, as explicitly stated in the sanctioning resolution, to two reasons: on the one hand, the commission of an infringement for the creation of the WhatsApp group was ruled out; and on the other hand, the infringement was initially considered to have been committed with intent, while it was ultimately considered that it was only committed negligently. This allowed for a total reduction of €135,000 (from €150,000 to €15,000).

This argument is now used in his favor by the appellant, indicating that the modification of the charge (from intent to negligence) prevented him from arguing about the latter. It is evident that this argument cannot prosper, as at all procedural moments the interested party had the opportunity to argue about this factor, which was already included from the very agreement to initiate the sanctioning file as an aggravating factor. In fact, this was taken into account by this Agency for the significant reduction of the sanction (which was reduced to only 10% of the initially proposed amount) in the final sanctioning resolution.

Thus, the possible intentionality of the infringement has not been taken into account as an aggravating factor of culpability (as it was in the initiation agreement). For its part, the concurrence of negligence in the infringement is sufficiently explained both in the sanctioning resolution itself and in the previous sections of this resolution.

Additionally, in the appeal for reconsideration, it is alleged that this Agency did not take into account various legally provided circumstances, which, in the opinion of the appellant, would lead to a

decrease in the amount:

- Art. 83.2.a) GDPR:

- The lack of seriousness and minimal duration of the alleged infringement: it would involve 2 emails very close in time and both addressed to the same recipients.

The existence of two emails, and both addressed to multiple recipients, prevents this circumstance from being considered as a mitigating factor. It should be clarified, moreover, that it has not been considered as an aggravating factor either.

- The nature, scope, or purpose of the processing operation in question: the object of the processing was to inform workers about COVID-related issues (public health). Similarly to the above, the commission of the infringement without having obtained consent from the affected parties is of such a nature that it prevents this circumstance from being considered as a mitigating factor. Like the previous circumstance, it has not been considered an aggravating factor either.

- The number of affected parties: the emails were sent to a total of 41 (almost all would be duplicates);

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/28

It cannot be considered that having affected multiple individuals, in this case 41, can be regarded as a mitigating factor. This is a significant number of individuals whose data was compromised.

o

The level of damages suffered: the appellant claims that there is no evidence that the alleged breach caused any damage or harm to any employee.

While the occurrence of damages could have been considered an aggravating factor, the operation cannot be performed in the opposite sense, such that it would reduce the amount of the sanction.

□

Art. 83.2.b) GDPR: there would have been no intent or negligence in the infringement. In this regard, if there had been neither intent nor negligence, the infringement could not have been attributed, as the regulation requires the presence of one of the two. In fact, the contested resolution specifies the reasons why negligence is considered to exist:

“The examination of the documentation in the file does not allow for the appreciation of diligent behavior on the part of the respondent, who sent two communications to a plurality of recipients without concealing the addresses. The respondent has not been able to justify that there were adequate security measures in place to ensure the confidentiality of the data in the mailings.

Furthermore, by sending communications to the personal email of employees without using the blind copy option, it implies that the security measures of the respondent are not adequate to data protection regulations.”

□

Art. 83.2.c) and f) GDPR: Measures taken. The appellant would have decided, after becoming aware of this case, to “adopt the measure of sending a communication to all its middle management to remind them that in ILUNION SEGURIDAD, S.A. both the creation of WhatsApp groups with the personal phone numbers of employees and the sending of emails without using the blind copy (BCC) option to the personal email addresses of those employees are prohibited.”

While the adoption of reactive measures to prevent future non-compliance is positively valued, the fact that they were adopted after becoming aware of the complaint prevents them from being considered as a mitigating factor.

□

Art. 83.2.e) GDPR: previous infringements committed by the controller: ILUNION SEGURIDAD, S.A. has not previously been sanctioned for violating data protection legislation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

This circumstance can only be considered as an aggravating factor in the presence of previous infringements. The Judgment of the National Court, dated May 5, 2021, rec. 1437/2020, indicates that “On the other hand, it should be appreciated as a mitigating factor the absence of a previous infringement. Well, Article 83.2 of the GDPR establishes that the following circumstance must be taken into account for the imposition of the administrative fine, among others: ‘e) any previous infringement committed by the controller or the processor.’ This is an aggravating circumstance; the fact that the prerequisite for its application does not exist means that it cannot be taken into consideration, but it does not imply or allow, as the plaintiff intends, its application as a mitigating factor.”

□

Art. 83.2.g) GDPR: categories of personal data affected by the infringement: the supposedly compromised data is only the email address, data that does not have the status, as claimed by the appellant, of specially protected data.

This circumstance cannot be considered as a mitigating factor. It should be noted that data such as email addresses are used for the production of certain frauds, such as phishing or identity theft.

□

Art. 83.2.k) GDPR: financial benefits obtained or losses avoided, directly or indirectly, through the infringement: neither benefits would have been obtained nor losses avoided, as the appellant indicates that in no case would the alleged infringement have had any intent.

Evaluating the absence of benefits as a mitigating factor would nullify the deterrent effect of the fine, as it diminishes the impact of the circumstances that effectively influence its quantification, providing the responsible party with a benefit to which they are not entitled. It would be an artificial reduction of the sanction that could lead to the understanding that violating the regulation without obtaining benefits, financial or otherwise, would not produce a negative effect proportional to the severity of the infringing act.

Regarding the precedents mentioned by the appellant, the following should be stated: first, it should be taken into account, as established in Article 83 of the GDPR, the turnover of the sanctioned entity.

Thus, as stated in the contested resolution, the relevant turnover for the interested party is 185 million euros.

Additionally, as our jurisprudence has repeatedly stated, there is no supposed right to “equality in illegality,” and the resolution motivates the circumstances on which it bases the determination of the amount.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

Furthermore, it remains to be said that for the infringements of Article 5.1.f) the GDPR provides for maximum penalties of 20 million euros, while for those of Article 32 the maximum would be 10 million. Thus, the amounts imposed are clearly within the minimum degree of what is legally provided.

V

Conclusion

Consequently, in the present appeal for reconsideration, the appellant has not provided facts or legal arguments that would allow for a reconsideration of the validity of the contested resolution.

VI

Late Resolution

Due to operational reasons of the administrative body, therefore not attributable to the appellant, as of the date hereof, the mandatory pronouncement of this Agency regarding the present appeal has not been issued.

In accordance with the provisions of Article 24 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the sense of administrative silence in the procedures for challenging acts and provisions is dismissive.

Nevertheless, despite the time elapsed, the Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their initiation form, as provided in Article 21.1 of the aforementioned LPACAP.

Therefore, it is appropriate to issue the resolution that concludes the procedure of the appeal for reconsideration filed.

Having seen the cited precepts and others of general application,
the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by ILUNION SEGURIDAD, S.A. against the resolution of this Spanish Agency for Data Protection issued on February 14, 2023, in file RR/00162/2023.

SECOND: TO NOTIFY this resolution to ILUNION SEGURIDAD, S.A.

THIRD: To warn the sanctioned party that the imposed penalty must be made effective once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period indicated in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it into the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection at CAIXABANK, S.A., or otherwise, collection will proceed in the executive period. Upon receipt of the notification and once it is executive, if the date of executive status falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

180-111122

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es